

Segmentacja sieci w średniej firmie

Praktyczne wskazówki i dobre zasady wdrożenia w środowisku różnorodnym

Materiał uzupełniający do kursu · wrzesień 2026

Po co segmentować?

Trzy niezależne powody — każdy sam w sobie uzasadnia projekt

1

Ograniczenie zasięgu ataku

Zainfekowana stacja nie widzi serwerów ani innych działów. Ruch poprzeczny (lateral movement) zatrzymuje się na granicy strefy.

2

Wydajność i stabilność

Mniejsze domeny rozgłoszeniowe, mniej ruchu multicast/discovery, krótsza rekonwergencja STP, prostsza diagnostyka.

3

Zgodność i rozliczalność

Dane kadrowe, księgowe, płatnicze i systemy przemysłowe w wydzielonych strefach z udokumentowaną polityką dostępu.

Zasada wyjściowa: segmentacja to projekt organizacyjny, nie tylko konfiguracja VLAN-ów.

Krok 0: inwentaryzacja

Bez tego każdy podział będzie zgadywaniem — i wróci jako awaria

Urządzenia końcowe

stacje, laptopy, telefony VoIP, drukarki, terminale, BYOD

Serwery i usługi

kto z czym się łączy, na jakich portach, w którą stronę

IoT / OT / automatyka

kamery, kontrola dostępu, sterowniki, klimatyzacja

Systemy legacy

aplikacje wymagające rozgłoszeń, stare protokoły, brak TLS

Zarządzanie

switchy, AP, UPS, iLO/iDRAC, konsole, monitoring

Dostęp zdalny

VPN, serwis zewnętrzny, dostawcy, oddziały

Produkt kroku 0: tabela „system → kto się łączy → czym → w którą stronę”. To ona definiuje granice stref.

Według czego dzielić

Kryterium decyduje o tym, czy polityka będzie dawała się utrzymać



Kryteria, które się bronią

- Rola i funkcja systemu (serwery, stacje, VoIP, druk, IoT)
- Poziom zaufania (wewnętrzne / gościnne / niezarządzane)
- Właściciel i odpowiedzialność za politykę
- Wymagania zgodności i wrażliwość danych
- Wymagany poziom dostępności i okna serwisowe



Kryteria, które mszczą się później

- Podział „po piętrach” i po szafach — ludzie się przesiadają
- Jeden VLAN na dział — dział rośnie, dzieli się, znika
- VLAN pod pojedynczą aplikację — dziesiątki mikrostref
- Podział pod aktualną topologię okablowania
- Podział „bo tak zostało po poprzedniku”

Wzorzec stref dla średniej firmy

Punkt wyjścia do adaptacji — zwykle 6–10 stref wystarcza

VLAN	Strefa	Co zawiera	Polityka wyjścia
10	Użytkownicy	stacje robocze, laptopy firmowe	serwery (wybrane porty) + internet
20	Serwery	usługi wewnętrzne, pliki, aplikacje	tylko odpowiedzi + aktualizacje
30	VoIP	telefony, brama głosowa	tylko centrala i SIP
40	Druk i peryferia	drukarki, skanery sieciowe	tylko z VLAN użytkowników
50	IoT / OT	kamery, kontrola dostępu, automatyka	tylko własny kontroler
60	Goście / BYOD	urządzenia niezarządzane	wyłącznie internet
99	Zarządzanie	SVI, switche, AP, konsole, monitoring	tylko z jump hosta
199	Native / parking	native trunku, porty nieużywane	brak — bez SVI, porty shutdown

Numeracja z zapasem (10, 20, 30...) — zostawia miejsce na strefę, której dziś nie przewidujesz.

Adresacja i nazewnictwo

Schemat, który da się odczytać z samego adresu IP

Zasady

- Numer VLAN = trzeci oktet: VLAN 20 → 10.10.20.0/24
- Brama zawsze ten sam adres w podsieci (.1 albo ostatni)
- Osobne pule: serwery statycznie, stacje z DHCP, rezerwacje dla drukarek
- Zapas adresowy 2x — rozrost jest tańszy niż renumeracja
- Nazwy VLAN opisowe i spójne: SERWERY, GOSCIE, ZARZADZANIE
- Jedno źródło prawdy: arkusz lub IPAM, aktualizowany przy każdej zmianie

Przykład zapisu

VLAN 10	UZYTKOWNICY	10.10.10.0/24	.1
VLAN 20	SERWERY	10.10.20.0/24	.1
VLAN 30	VOIP	10.10.30.0/24	.1
VLAN 40	DRUK	10.10.40.0/24	.1
VLAN 50	IOT	10.10.50.0/24	.1
VLAN 60	GOSCIE	10.10.60.0/24	.1
VLAN 99	ZARZADZANIE	10.10.99.0/24	.1

Adres urządzenia mówi, w jakiej jest strefie — bez zaglądania do dokumentacji.

Gdzie spotykają się strefy

Routing między VLAN-ami to jednocześnie punkt egzekwowania polityki

1

Przełącznik warstwy 3

Bramy jako SVI w rdzeniu. Najwydajniejsze, ruch nie wychodzi poza przełącznik. Polityka: ACL na SVI.

2

Router / firewall na styku

Wszystkie strefy przez firewall. Pełna inspekcja i logi, ale przepustowość i opóźnienie są wąskim gardłem.

3

Model mieszany

Ruch wewnętrzny na L3 w rdzeniu, strefy wrażliwe (goście, IoT, DMZ) wpięte przez firewall. Najczęstszy wybór.

Pułapka: brama w jednym miejscu, polityka w drugim. Jeśli ruch nie przechodzi przez punkt kontroli, reguła nie zadziała.

Polityka ruchu między strefami

Domyślnie zabronione, wyjątki wypisane i uzasadnione

Zasady pisania reguł

- Domyślnie deny między strefami, permit tylko wypisany
- Reguła jak najbliżej źródła ruchu
- Każdy wyjątek ma właściciela, powód i datę przeglądu
- Ruch zwrotny: pamiętaj o kierunku (echo-reply, established)
- Zarządzanie dostępne tylko z jednej strefy
- Logowanie odrzuceń — inaczej nie wiesz, co blokujesz

Szkic reguł (Cisco IOS)

```
ip access-list extended UZYTK_OUT
  permit tcp 10.10.10.0 0.0.0.255
    host 10.10.20.10 eq 445
  permit udp 10.10.10.0 0.0.0.255
    host 10.10.20.10 eq 53
  deny ip 10.10.10.0 0.0.0.255
    10.10.0.0 0.0.255.255 log
  permit ip any any
!
interface Vlan10
  ip access-group UZYTK_OUT in
```

Strefa zarządzania

Najczęściej pomijana, a to ona decyduje o skutkach włamania

1 Osobny VLAN zarządzania

SVI przełączników, AP, UPS, karty iLO/iDRAC — nigdy w VLAN-ie użytkowników.

2 Dostęp tylko z jump hosta

Lista dostępu na liniach VTY, adres źródłowy ograniczony do stacji administracyjnych.

3 SSH zamiast Telnetu

Konta imienne, uwierzytelnianie centralne, hasła enable jako zabezpieczenie awaryjne.

4 Native VLAN inny niż 1

VLAN 1 nieużywany na żadnym porcie; native trunku dedykowany i bez ruchu użytkowego.

5 Poza pasmem, jeśli można

Konsola / port zarządzania dostępny nawet wtedy, gdy sieć produkcyjna leży.

Goście, BYOD i sprzęt serwisantów

Wszystko, czego nie zarządzasz, traktuj jak sieć publiczną

Goście i BYOD

- Osobny VLAN i osobna pula DHCP — nigdy wspólna z pracownikami
- Wyjście wyłącznie do internetu, zero dostępu do zasobów wewnętrznych
- Izolacja klientów między sobą (port protected / client isolation na AP)
- Ograniczenie pasma, żeby gość nie zablokował łącza firmowego
- Regulamin i rotacja hasła Wi-Fi albo portal z kodami czasowymi

Dostawcy i serwis

- Serwisant zewnętrzny: port w strefie serwisowej, dostęp na czas zlecenia
- Dostęp zdalny dostawcy przez VPN z kontem imiennym, nie współdzielonym
- Wyłączony DHCP-relay do wewnętrznych serwerów
- DNS gościnny osobny — bez wewnętrznych stref DNS
- Logowanie: kto, kiedy, z jakiego adresu — także dla gości

Higiena portów dostępowych

Segmentacja bez zabezpieczenia portu jest tylko umową dżentelmeńską

Na każdym porcie użytkownika

- Port Security — limit adresów MAC i reakcja na naruszenie
- DHCP Snooping — zaufane tylko porty w stronę serwera DHCP
- Dynamic ARP Inspection — oparty na bazie snoopingu
- BPDU Guard + PortFast na portach do stacji
- Porty nieużywane: VLAN parkingowy + shutdown
- Wyłączone negocjowanie trunku na portach dostępowych

Wzorzec portu dostępowego

```
interface range Fa0/2-20
  switchport mode access
  switchport access vlan 10
  switchport nonegotiate
  switchport port-security
  switchport port-security maximum 2
  switchport port-security violation
    restrict
  spanning-tree portfast
  spanning-tree bpduguard enable
  no cdp enable
```

Trunki — co przepuszczać

Trunk domyślny przenosi wszystkie VLAN-y; to przeciwieństwo segmentacji

1

Lista dozwolonych

switchport trunk allowed vlan — tylko strefy faktycznie potrzebne po drugiej stronie.

2

Dedykowany native

Native VLAN bez ruchu użytkowego, ten sam po obu stronach łączy.

3

Statyczny tryb

Trunk konfigurowany ręcznie, negocjacja wyłączona (nonegotiate).

4

Spójność z agregacją

Przy EtherChannel identyczne parametry na interfejsie Port-channel i portach członkowskich.

5

Przegląd okresowy

Po każdym dodaniu VLAN-u sprawdź, czy przeszedł przez wszystkie trunki po drodze.

Sprawdzenie: show interfaces trunk — kolumna „Vlans allowed and active in management domain”.

IoT, OT i systemy legacy

Tu segmentacja najczęściej psuje działające rzeczy

Problem	Dlaczego boli	Co zrobić
Wykrywanie w sieci (mDNS, SSDP, NetBIOS)	Działa tylko w jednej domenie rozgłoszeniowej — po podziale drukarka „znika”.	Rezerwacja DHCP + port instalowany ręcznie po adresie IP; ewentualnie repeater mDNS.
Kamery i rejestratory	Duży, stały strumień; często twardo wpisane adresy i brak bramy.	Własna strefa z dostępem tylko do rejestratora i stacji operatora.
Automatyka i sterowniki	Protokoły bez uwierzytelniania, wrażliwe na opóźnienia i skanowanie.	Strefa odcięta domyślnie; wyjątki tylko do systemu nadrzędnego; bez skanów podatności.
Aplikacje legacy	Wymagają rozgłoszeń lub sztywnej podsieci, brak wsparcia producenta.	Zostawić we własnej strefie i wystawić wyłącznie potrzebne porty; udokumentować dług.

Zasada: zanim odetniesz, zmierz. Tydzień logów z zapory pokazuje, kto naprawdę z kim rozmawia.

Wdrożenie etapami

Nigdy „wszystko w jeden weekend” — polityka dojrzeźwa stopniowo

1 Pomiar

Zbierz ruch i zależności. Zapora w trybie tylko-logowanie.

2 Projekt

Strefy, adresacja, macierz dostępu zatwierdzona przez właścicieli.

3 Pilot

Jedna strefa, jeden przełącznik, grupa ochotników. Plan wycofania.

4 Rozszerzanie

Kolejne strefy w oknach serwisowych; po każdej — weryfikacja.

5 Zaciskanie

Zamiana permit-any na listę wyjątków. Dopiero teraz default-deny.

6 Utrzymanie

Przegląd wyjątków, aktualizacja dokumentacji, monitoring odrzuceń.

Każdy etap kończy się testem i wpisem w dokumentacji. Brak wpisu = etap niezakończony.

Typowe błędy

Powtarzają się niezależnie od branży i wielkości firmy



Zbyt drobny podział

Kilkadziesiąt stref, których nikt nie utrzyma. Lepiej mniej stref z dobrą polityką.



Reguła „tymczasowa”

permit ip any any „na czas testów” zostaje na lata. Wyjątek bez daty przeglądu nie istnieje.



Brak logowania odrzuceń

Nie wiadomo, co się zepsuło i czy blokada w ogóle działa.



Zarządzanie w tym samym VLAN-ie

Przejęta stacja użytkownika = dostęp do przełączników.



Dokumentacja po wdrożeniu

Powstaje „później”, czyli nigdy. Rysunek i macierz powstają przed konfiguracją.



Zapomniany trunk

Nowa strefa działa lokalnie, ale nie przechodzi przez łącze do drugiego budynku.

Checklista wdrożeniowa

Do wydruku — jedna kolumna na etap projektu

Przed projektem

- ☐ Inwentarz urządzeń i usług
- ☐ Mapa zależności (kto z kim)
- ☐ Właściciele systemów wskazani
- ☐ Wymagania zgodności spisane
- ☐ Zgoda na okna serwisowe

Projekt

- ☐ Lista stref i kryterium podziału
- ☐ Plan adresacji z zapasem
- ☐ Macierz dostępu między strefami
- ☐ Miejsce egzekwowania polityki
- ☐ Plan wycofania każdego etapu

Po wdrożeniu

- ☐ Testy dostępu zgodne z macierzą
- ☐ Logowanie odrzuceń włączone
- ☐ Dokumentacja zaktualizowana
- ☐ Porty nieużywane wyłączone
- ☐ Termin przeglądu wyjątków

Weryfikacja po wdrożeniu

Co sprawdzić, zanim ogłosisz zakończenie etapu

Testy funkcjonalne

- Z każdej strefy: co ma działać — działa
- Z każdej strefy: co ma być odcięte — jest odcięte
- Drukowanie, telefony, kamery, aplikacje legacy
- DHCP w każdej strefie i poprawna brama
- Dostęp administracyjny tylko z jump hosta

Polecenia kontrolne

```
show vlan brief
show interfaces trunk
show interfaces status
show ip interface brief
show ip access-lists
show port-security interface Fa0/2
show ip dhcp snooping binding
show spanning-tree vlan 10
```